ThreatSimGPT Audit Logging Policy

Document Control

Field	Information
Version	1.0
Effective Date	January 20, 2026
Last Updated	January 20, 2026
Document Owner	Compliance Team
Author	Jeremiah Okino
Legal Basis	SOC 2 CC7.2, PCI-DSS Requirement 10, HIPAA 164.312(b)
Classification	Internal Use - Confidential

Overview

This policy establishes the requirements for audit logging across all ThreatSimGPT systems and services. It defines what must be logged, how logs must be formatted, and the controls required to ensure log integrity.

---

1. Logging Requirements

Section 1.1 Mandatory Logging

All systems MUST log the following event categories:

Category	Events	Retention
Authentication	Login success/failure, logout, session creation/destruction, MFA events	1 year
Authorization	Access granted/denied, privilege escalation, role changes	1 year
Data Access	Create, read, update, delete operations on sensitive data	90 days
Configuration	System settings changes, policy updates, feature toggles	2 years
Security	Failed access attempts, policy violations, anomaly detections	2 years
Administrative	User management, system administration actions	2 years

Section 1.2 Required Log Fields

Every audit log entry MUST contain:

Field	Description	Required
timestamp	ISO 8601 format with timezone (UTC)	Yes

event_id	Unique identifier for the event	Yes
event_type	Hierarchical event type identifier	Yes
severity	Syslog-aligned severity level (0-7)	Yes
actor.user_id	Identifier of the acting user	Yes (if applicable)
actor.ip_address	Source IP address	Yes
target.resource_type	Type of resource affected	Yes (if applicable)
target.resource_id	Identifier of affected resource	Yes (if applicable)
outcome.status	success, failure, error	Yes
checksum	SHA-256 hash for integrity	Yes

Section 1.3 Conditional Fields

Field	When Required
actor.username	When user context exists
actor.user_agent	For HTTP requests
context.session_id	When session exists
context.request_id	For request tracing
context.correlation_id	For distributed tracing
outcome.reason	When outcome is not success
outcome.error_code	When error occurs

---

2. Log Format Specification

Section 2.1 Standard Format

All logs MUST use JSON format with the following structure:

```
{
  "version": "1.0",
  "timestamp": "2026-01-20T12:00:00.000Z",
  "event_id": "evt_01HN5XYZABC123DEF456",
  "event_type": "authentication.login.success",
  "severity": 6,
  "severity_label": "INFO",
  "actor": {
    "user_id": "usr_abc123",
    "username": "john.doe@example.com",
    "ip_address": "192.168.1.100",
    "user_agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64)",
    "geo_location": {
```

```
      "country": "US",
      "region": "CA",
      "city": "San Francisco"
    }
  },
  "target": {
    "resource_type": "session",
    "resource_id": "sess_xyz789",
    "resource_name": "user_session"
  },
  "context": {
    "session_id": "sess_xyz789",
    "request_id": "req_def456",
    "correlation_id": "corr_ghi789",
    "trace_id": "trace_jkl012"
  },
  "outcome": {
    "status": "success",
    "reason": null,
    "error_code": null,
    "duration_ms": 150
  },
  "metadata": {
    "service": "auth-service",
    "version": "2.1.0",
    "environment": "production",
    "datacenter": "us-west-2"
  },
  "extensions": {},
  "checksum": "sha256:a1b2c3d4e5f6..."
}
```


Section 2.2 CEF Export Format

For SIEM integration, logs can be exported in Common Event Format:

```
CEF:0|ThreatSimGPT|AuthService|2.1.0|AUTH_LOGIN_SUCCESS|User Login Success|3|
src=192.168.1.100 suser=john.doe@example.com dst=auth-service
duser=usr_abc123 outcome=success rt=Jan 20 2026 12:00:00
```

Section 2.3 Syslog Format

For syslog forwarding:

```
<134>1 2026-01-20T12:00:00.000Z auth-service threatsimgpt 12345 AUTH_LOGIN_SUCCESS
[auth@12345 user_id="usr_abc123" ip="192.168.1.100" outcome="success"] User login
successful
```

---

3. Logging Controls

Section 3.1 Log Generation Controls

Control	Requirement
Centralized logger	All services use shared AuditLogger
Structured output	JSON format with schema validation
Timestamp accuracy	NTP synchronized, millisecond precision
Unique identifiers	ULIDs for event IDs (time-sortable)
Correlation	Request/session/trace IDs propagated

Section 3.2 Log Transmission Controls

Control	Requirement
Encryption	TLS 1.3 for log transmission
Authentication	Mutual TLS for log shippers
Buffering	Local buffer for network failures
Compression	Gzip compression for efficiency
Acknowledgment	At-least-once delivery guarantee

Section 3.3 Log Storage Controls

Control	Requirement
Encryption at rest	AES-256 encryption
Access control	Role-based access to log data
Immutability	Write-once storage for audit logs
Replication	Minimum 3 replicas across zones
Backup	Daily backups with 30-day retention

---

4. Prohibited Logging

Section 4.1 Never Log

The following data MUST NOT appear in logs:

Data Type	Reason
Passwords	Security risk
API keys/tokens	Security risk
Credit card numbers	PCI-DSS compliance
Social Security Numbers	Privacy/compliance

Full bank account numbers	PCI-DSS compliance
Encryption keys	Security risk
Session tokens (full)	Security risk
PHI (unmasked)	HIPAA compliance

Section 4.2 Masking Requirements

Data Type	Masking Rule	Example
Email	Show domain only	***@example.com
IP (internal)	Last octet masked	192.168.1.***
Credit card	First 6, last 4	411111******1234
Phone	Last 4 digits	---1234
SSN	Fully masked	---***
API keys	First 4 characters	sk_l***

---

5. Log Access Control

Section 5.1 Access Roles

Role	Permissions	Approval Required
Log Administrator	Full access, configuration	Security Lead
Security Analyst	Read all, create alerts	Security Lead
Compliance Auditor	Read compliance events	Audit Lead
Developer	Read own service logs	Manager
Support	Read sanitized logs	Support Lead

Section 5.2 Access Logging

All log access MUST be logged:

Event	Details Captured
Query execution	Query text, user, timestamp, results count
Export	Format, date range, destination, user
Alert creation	Rule definition, user, timestamp
Dashboard view	Dashboard ID, user, timestamp

---

6. Log Monitoring and Alerting

Section 6.1 Mandatory Alerts

Alert	Condition	Severity	Response
Multiple failed logins	More than 5 failures in 5 minutes	High	Account lockout review
Privilege escalation	Admin role granted	Critical	Immediate review
Data export	Bulk data download	Medium	Activity review
Off-hours access	Access outside business hours	Low	Next-day review
New country login	Login from new geography	Medium	User verification
Service account usage	Service account interactive login	High	Immediate review

Section 6.2 Alert Configuration

```yaml
alerts:
  - name: multiple_failed_logins
    description: Detect brute force attempts
    query: |
      event_type:authentication.login.failure
      | stats count by actor.user_id
      | where count > 5
    window: 5m
    severity: high
    actions:
      - notify: security-team
      - create_ticket: true

  - name: privilege_escalation
    description: Admin role assignment
    query: |
      event_type:authorization.role.grant
      AND target.role:admin
    severity: critical
    actions:
      - notify: security-team
      - page: on-call
```

---

7. Compliance Validation

Section 7.1 Logging Compliance Checks

Check	Frequency	Owner
Required fields present	Continuous	Automated
Retention compliance	Daily	Automated
Encryption verification	Weekly	Security

Access review	Quarterly	Compliance
Coverage audit	Monthly	Technical Lead

Section 7.2 Compliance Evidence

Evidence Type	Generation	Storage
Log samples	Daily automated	Evidence repository
Coverage reports	Weekly automated	Compliance dashboard
Access reports	Monthly	Compliance repository
Integrity reports	Daily automated	Security dashboard

---

8. Exception Handling

Section 8.1 Exception Process

Step	Action	Owner
1	Document exception request	Requestor
2	Risk assessment	Security
3	Approval decision	Audit Lead
4	Implementation with controls	Technical Lead
5	Periodic review	Audit Committee

Section 8.2 Exception Documentation

Field	Required
Exception ID	Yes
Requestor	Yes
Justification	Yes
Risk assessment	Yes
Compensating controls	Yes
Expiration date	Yes
Approver	Yes

Document Control

Version	Date	Author	Changes
1.0	2026-01-20	Jerry (okino007)	Initial release

This policy is enforced across all ThreatSimGPT systems and services.